

Day144 免杀对抗-Webshell篇&静态查杀&行为拦截&流量监控&代码混淆&内存加载&工具魔改



1.知识点

- 1、环境准备-单机系统&杀毒产品&流量产品
- 2、Webshell-静态对抗&动态对抗&工具对抗
- 3、Webshell-代码混淆&流量绕过&源码魔改

2.详细点



- 1 1、认知需要免杀的对象有哪些
- 2 -各类杀毒产品，EDR，微步平台产品等
- 3 2、认知需要免杀的目标有哪些
- 4 -webshell/内存马
- 5 -C2/CS类远控后门
- 6 -渗透测试安全工具类
- 7 -红队APT钓鱼文档类
- 8 3、认知需要免杀的技术有哪些
- 9 静态手法，动态手法，保护手法，源码魔改等

3.演示案例



- 1 实战场景：
- 2 某X60全家桶下的web环境，webshell植入后的渗透测试对抗情况。
- 3
- 4 准备：
- 5 1、环境准备-单机系统&杀毒产品&流量产品
- 6 2、反编译打包环境-IDEA安装&反编译工具
- 7
- 8 引出问题：
- 9 1、webshell工具里面的后门代码不被杀毒检测到-混淆
- 10 2、webshell工具里面的功能操作不被杀毒拦截到-魔改
- 11 3、webshell工具里面的操作连接不被平台捕获到-魔改
- 12
- 13 检测冰蝎后门：（冰蝎几个版本）
- 14 安装：apt install suricata
- 15 监控：suricata -c /etc/suricata/suricata.yaml -i eth0 -s /etc/suricata/rules/Behinder3.rules
- 16 查看：cat /var/log/suricata/fast.log
- 17
- 18 suricata规则下载：
- 19 0.
- 20 <https://github.com/a10ne/suricata-rules>
- 21 <https://github.com/ptresearch/AttackDetection>
- 22 1.
- 23 规则集名称：Proofpoint -- Emerging Threats Open Ruleset [et/open]
- 24 获取：<https://rules.emergingthreats.net/open/>
- 25 2.
- 26 规则集名称：Proofpoint -- Emerging Threats Pro Ruleset [et/pro]
- 27 获取：https://rules.emergingthreats.net/PRO_download_instructions.html
- 28 3.
- 29 规则集名称：OISF -- Suricata Traffic ID ruleset [oisf/trafficid]
- 30 获取：<https://openinfosecfoundation.org/rules/trafficid/trafficid.rules>

```
31 4.
32 规则集名称: Positive Technologies -- Positive Technologies Attack Detection Team ruleset
    [ptresearch/attackdetection]
33 获取:
    https://raw.githubusercontent.com/ptresearch/AttackDetection/master/pt.rules.tar.gz
34 5.
35 规则集名称: Secureworks -- Secureworks suricata-enhanced ruleset [scwx/enhanced]
36 获取: https://www.secureworks.com/contact/
37 6.
38 规则集名称: Secureworks -- Secureworks suricata-malware ruleset
39 获取: https://www.secureworks.com/contact/
40 7.
41 规则集名称: Secureworks -- Secureworks suricata-security ruleset [scwx/security]
42 获取: https://www.secureworks.com/contact/
43 8.
44 规则集名称: Abuse.ch -- Abuse.ch SSL Blacklist
45 获取: https://sslbl.abuse.ch/blacklist/sslblacklist.rules
46 9.
47 规则集名称: Abuse.ch -- Abuse.ch Suricata JA3 Fingerprint Ruleset [sslbl/ja3-
    fingerprints]
48 获取: https://sslbl.abuse.ch/blacklist/ja3_fingerprints.rules
49 10.
50 规则集名称: Etnetera a.s. -- Etnetera aggressive IP blacklist
51 获取: https://security.etnetera.cz/feeds/etn_aggressive.rules
52 11.
53 规则集名称: tgreen -- Threat hunting rules [tgreen/hunting]
54 获取: https://raw.githubusercontent.com/travisbgreen/hunting-rules/master/hunting.rules
55 12.
56 规则集名称: malsilo -- Commodity malware rules [malsilo/win-malware]
57 获取:
58 https://malsilo.gitlab.io/feeds/dumps/malsilo.rules.tar.gz
59 13.
60 规则集名称: Stamus Networks -- Lateral movement rules [stamus/lateral]
61 获取:
62 https://ti.stamus-networks.io/open/stamus-lateral-rules.tar.gz
```